Introduction to Computer Security and Threat Landscape

Dr Tauseef Ahmed

Senior Lecturer

Module Leader and Course Leader

Introduction to Computer Security

Overview and Learning Objectives



Cybersecurity Threat Introduction

The module introduces various cybersecurity threats and their significance in the digital world.

Key Learning Objectives

Students will learn to identify, describe, and defend against multiple types of cyber threats and vulnerabilities.

Comprehensive Threat Coverage

Topics include deception methods, cyber attacks, wireless vulnerabilities, application attacks, and threat actors.

Building Defense Strategies

Understanding threats is essential for developing robust defense strategies against evolving cyber attacks.

The NIST Internal/Interagency Report NISTIR 7298 (Glossary of Key Information Security Terms, July 2019) Defines the Term Computer Security as Follows:

“ Measures and controls that ensure **confidentiality, integrity**, and **availability** of information processed and stored by a computer, including hardware, software, firmware, information data, and telecommunications.”

Key Concepts



Threats

A threat represents a potential danger that can harm valuable assets in a digital environment.

Vulnerabilities

Vulnerabilities are weaknesses in systems or software that attackers can exploit to cause harm.

Attack Surface

Attack surface includes all the entry points where attackers can try to access a system or network.

Exploits

Exploits use vulnerabilities to compromise systems; while



Risk

A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of 1) the adverse impacts that would arise if the circumstance or event occurs; and 2) the likelihood of occurrence.

Security Policy

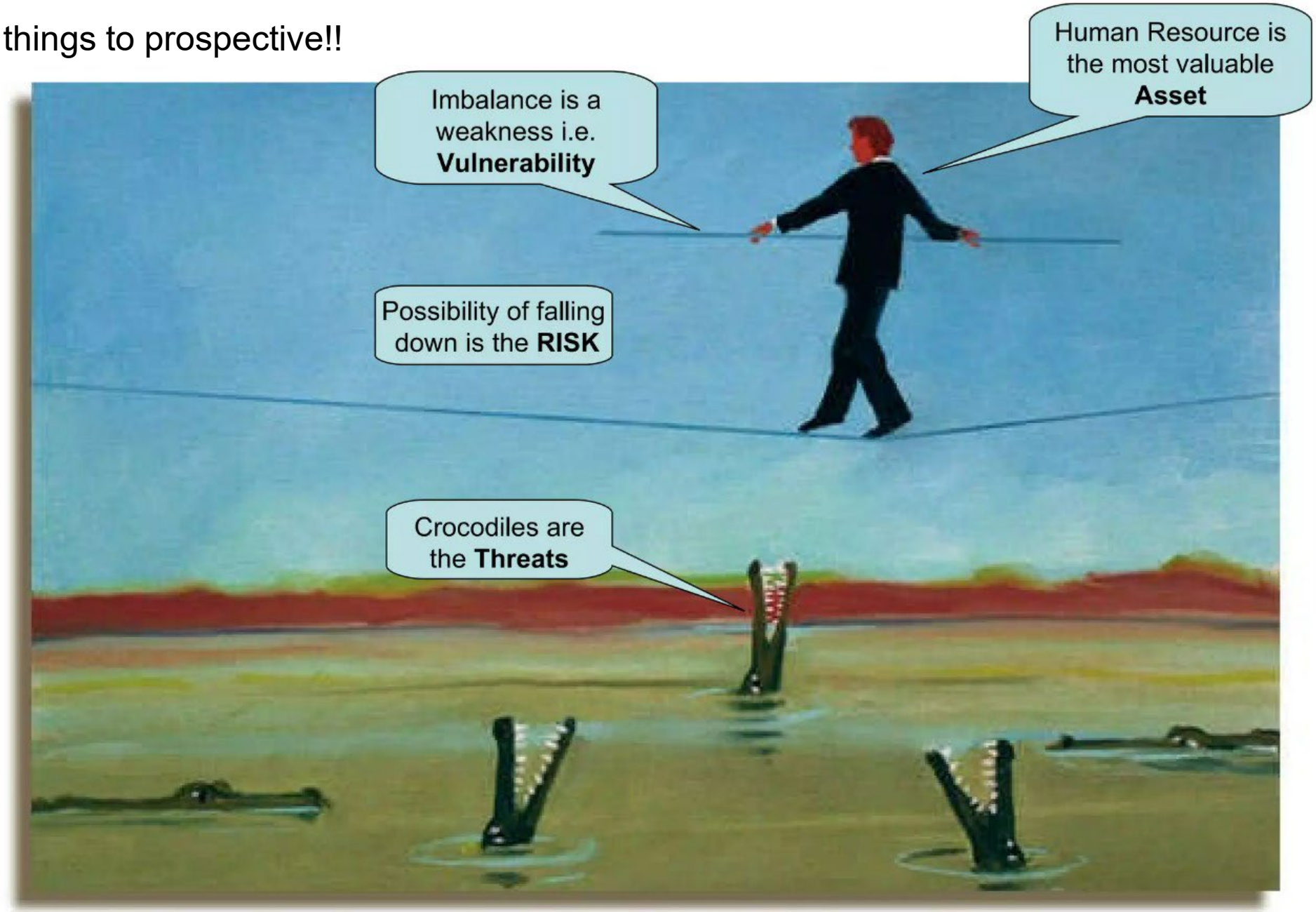
A set of criteria for the provision of security services. It defines and constrains the activities of a data processing facility in order to maintain a condition of security for systems and data.

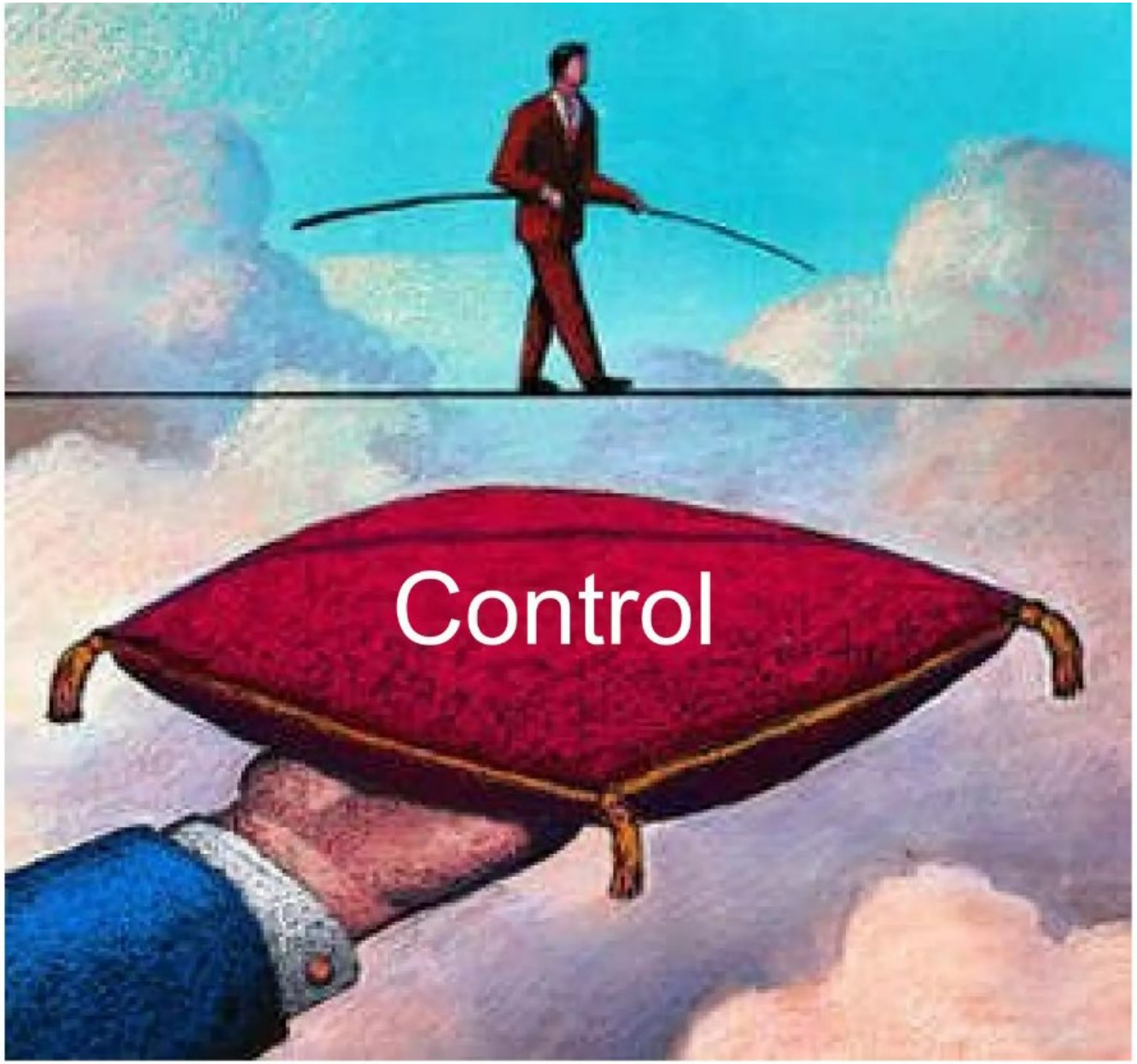
System Resource (Asset)

A major application, general support system, high impact program, physical plant, mission critical system, personnel, equipment, or a logically related group of systems.



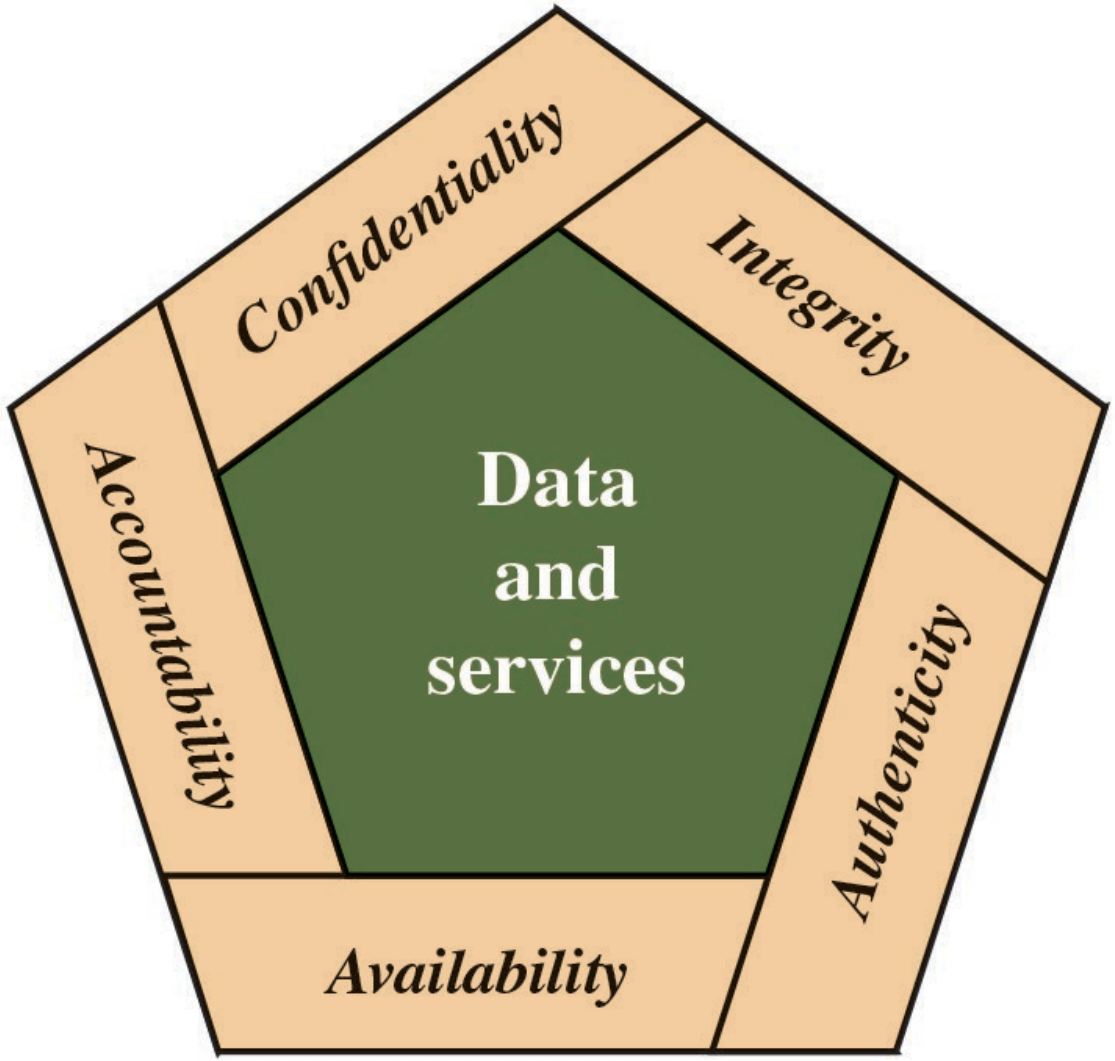
Putting things to prospective!!





Any type of preventive measure that can avoid the unfavourable circumstances

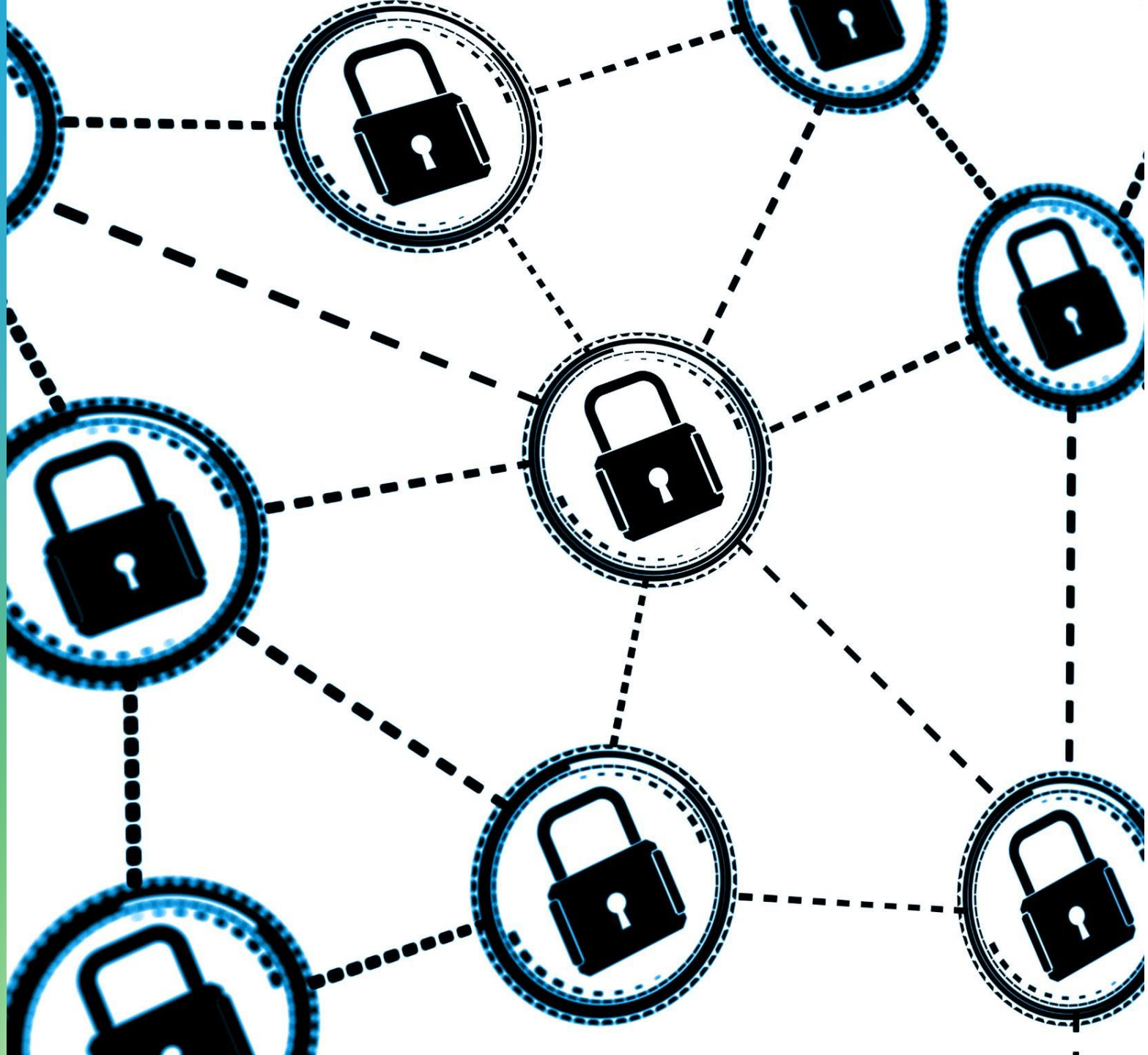
Essential Network and Computer Security Requirements



Key Security Concepts

Confidentiality	• Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information
Integrity	• Guarding against improper information modification or destruction, including ensuring information nonrepudiation and authenticity
Availability	• Ensuring timely and reliable access to and use of information

Common Cybersecurity Threats



Threat Domains and Types

Cybersecurity Domains

Threats exist across multiple domains such as physical access, wireless networks, social media, and cloud applications.

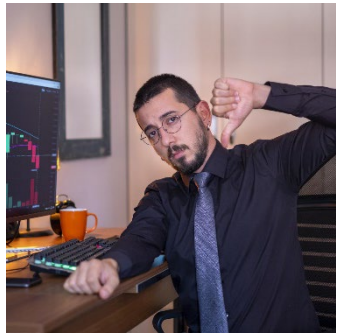
Types of Threats

Threats include software attacks, human errors, sabotage, theft, hardware failures, utility interruptions, and natural disasters.

Vulnerabilities and Defense

Each domain has unique vulnerabilities; understanding them helps develop targeted defense mechanisms.

Internal and External Threats



Internal Threats

Internal threats come from employees or partners who may unintentionally or deliberately harm systems or data.



External Threats

External threats involve attackers exploiting network vulnerabilities or using social engineering tactics.



Importance of Awareness and Controls

Distinguishing threat types helps implement policies, user awareness, and secure infrastructure to reduce risks.

Computer and Network Assets – Examples of Threats

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.	An unencrypted USB drive is stolen.	A door sensor is replaced with one that sends a closed status, regardless of actual door position, at certain times.
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communica-tion Lines and Networks	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

User and Device Vulnerabilities

User Threats and Device Risks



User Vulnerabilities

Users often pose risks due to lack of cybersecurity awareness and poor enforcement of policies.

Device Threats

Devices face risks from unattended use, unsafe downloads, outdated software, and unauthorized media.

Importance of Training

Regular user education and strict policy enforcement help reduce cybersecurity vulnerabilities.

Data Protection Goals

Maintaining data **confidentiality**, **integrity**, and **availability** is essential for robust security.

Network and Cloud Threats



Local Network Threats

Unauthorized access and software vulnerabilities threaten local area networks, risking data integrity and privacy.

Public Cloud Risks

Public clouds like SaaS, PaaS, and IaaS face risks due to shared infrastructure and potential misconfigurations.

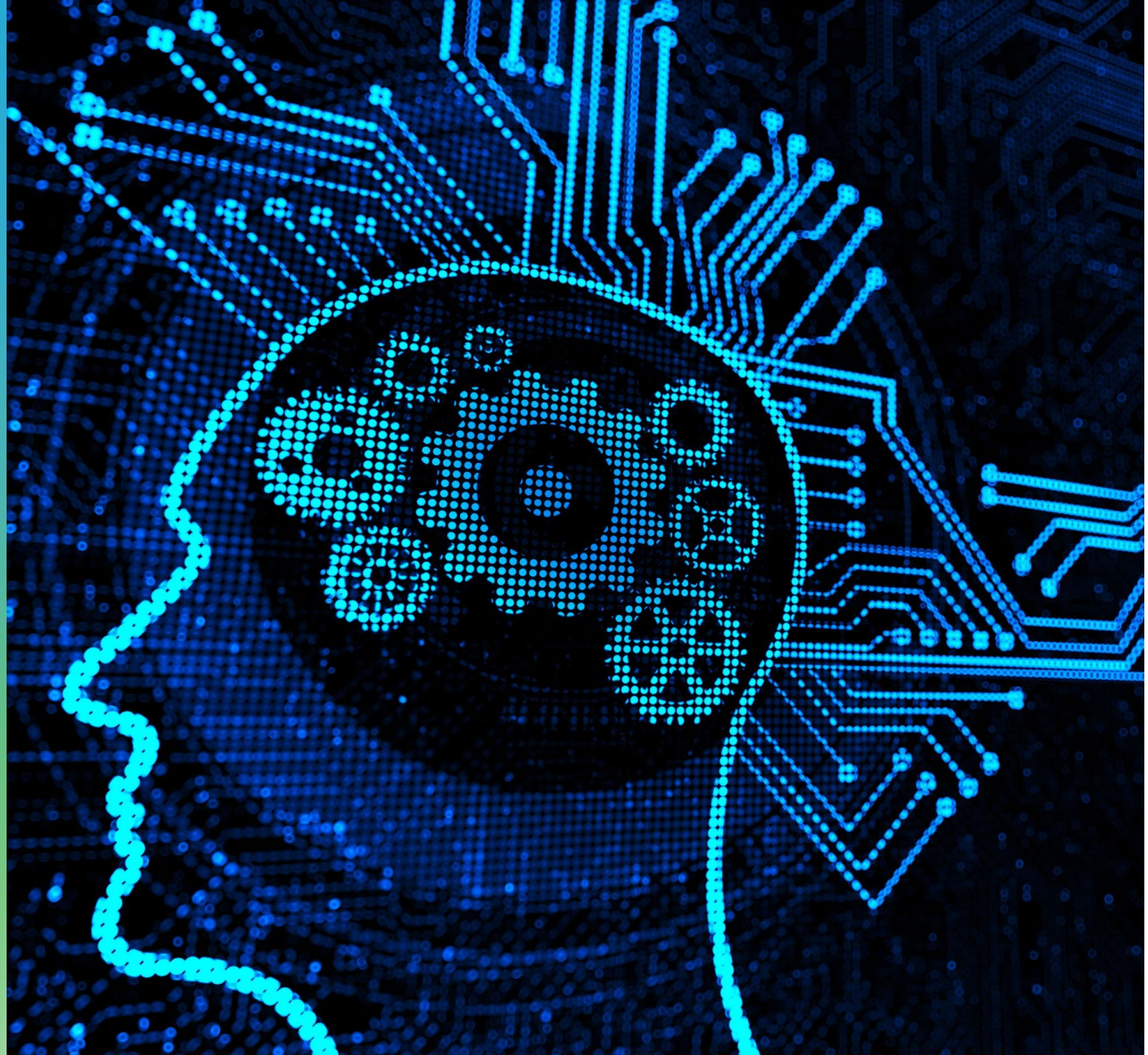
Private Cloud Threats

Private clouds are vulnerable to remote access issues and configuration errors that can expose sensitive data.

Security Awareness

Understanding network and cloud threats enables designing secure architectures and implementing strong security measures.

Deception Techniques



Social Engineering and Impersonation

Techniques of Social Engineering

Common tactics include pretexting, quid pro quo, identity fraud, and impersonation to manipulate victims.

Psychological Manipulation

Attackers use authority, urgency, and trust to influence victims and extract sensitive information.

Recognizing and Resisting Attacks

Education on vigilance and secure communication helps individuals detect and avoid social engineering scams.



Physical and Digital Deception

Physical Deception Techniques

Physical deception includes tactics like shoulder surfing, dumpster diving, piggybacking, and tailgating to gain unauthorized access.

Digital Deception Methods

Digital deception covers invoice scams, watering hole attacks, typosquatting, and influence campaigns targeting organizations online.

Importance of Awareness

Educating users and enforcing policies is essential to prevent deception-based security breaches and protect organizations.

Cyber Attack Methods

Active Attack

- Attempts to alter system resources or affect their operation
- Involve some modification of the data stream or the creation of a false stream
- Four categories:
  - Replay
  - Masquerade
  - Modification of messages
  - Denial of service

Passive Attack

- Attempts to learn or make use of information from the system, but it does not affect system resources
- Eavesdropping on, or monitoring of, transmissions
- Goal of attacker is to obtain information that is being transmitted
- Two types:
  - Release of message contents
  - Traffic analysis



Malware and Ransomware

Types of Malware

Viruses, worms, and trojans are common malware used by cybercriminals to damage or access systems illegally.

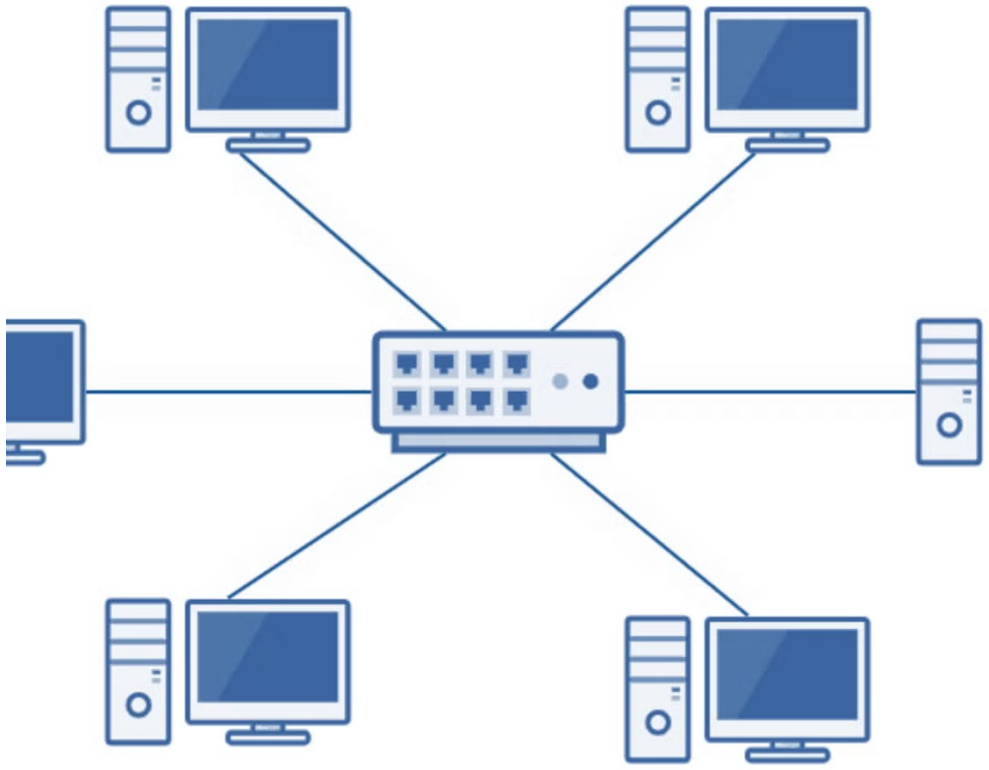
Ransomware Threat

Ransomware encrypts user data and demands payment, posing serious risks to personal and organizational information.

Cybersecurity Defenses

Antivirus software, regular updates, and cautious user behavior are vital to defend against malware and ransomware attacks.

Network and DNS Attacks



Denial of Service Attacks

These attacks overwhelm systems with excessive traffic or malformed packets to disrupt services.

DNS Attacks

DNS attacks include spoofing, hijacking, and cache poisoning to manipulate domain name resolution.

Layer 2 and Man-in-the-Middle Attacks

Layer 2 attacks use MAC and IP spoofing; MitM and MitMO intercept and alter communications.

Mitigation Techniques

Configuring firewalls, monitoring traffic, and applying patches help defend against network threats.

Wireless and Mobile Threats



Grayware and Rogue Access Points

Grayware Applications

Grayware consists of unwanted software that can monitor and track user behavior, posing privacy risks.

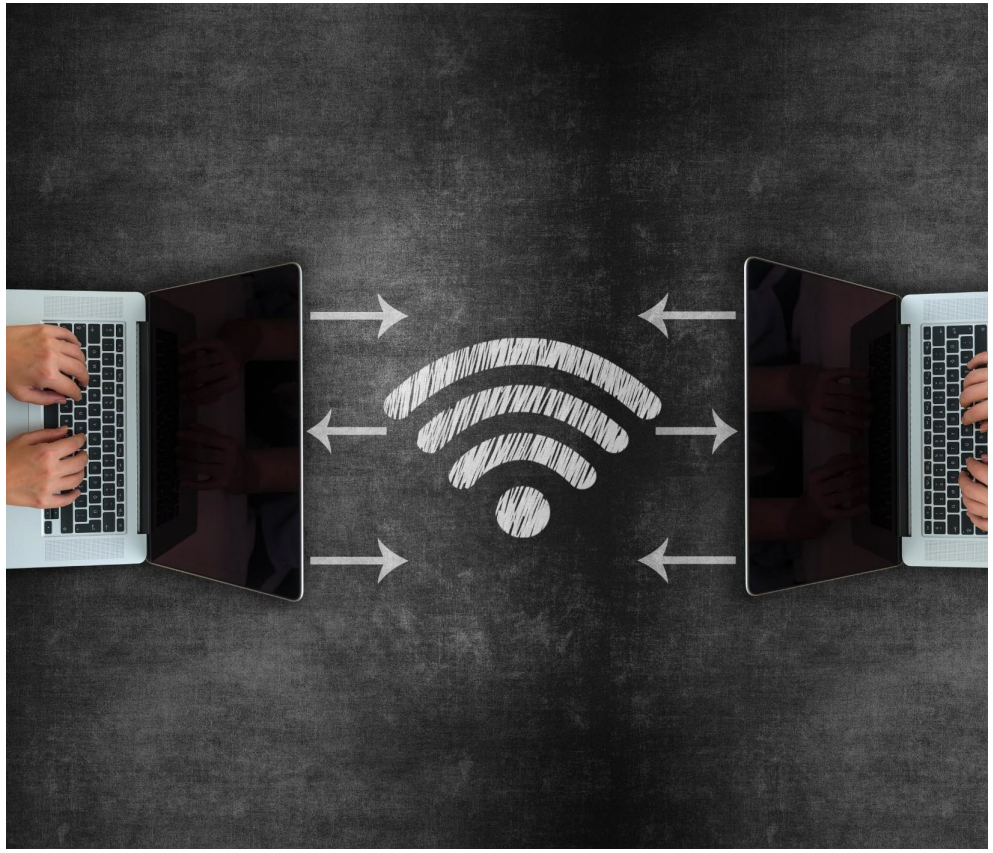
Rogue Access Points

Rogue access points are unauthorized devices imitating legitimate networks to intercept data and cause breaches.

Detection and Prevention

Learning the use tools and configurations to detect and block rogue access points effectively.

Bluetooth and Wi-Fi Attacks



Bluetooth Attack Methods

Bluejacking and bluesnarfing exploit device proximity to intercept Bluetooth communications and steal data.

Wi-Fi Protocol Vulnerabilities

WEP and WPA weaknesses allow attackers to breach Wi-Fi networks and access sensitive information.

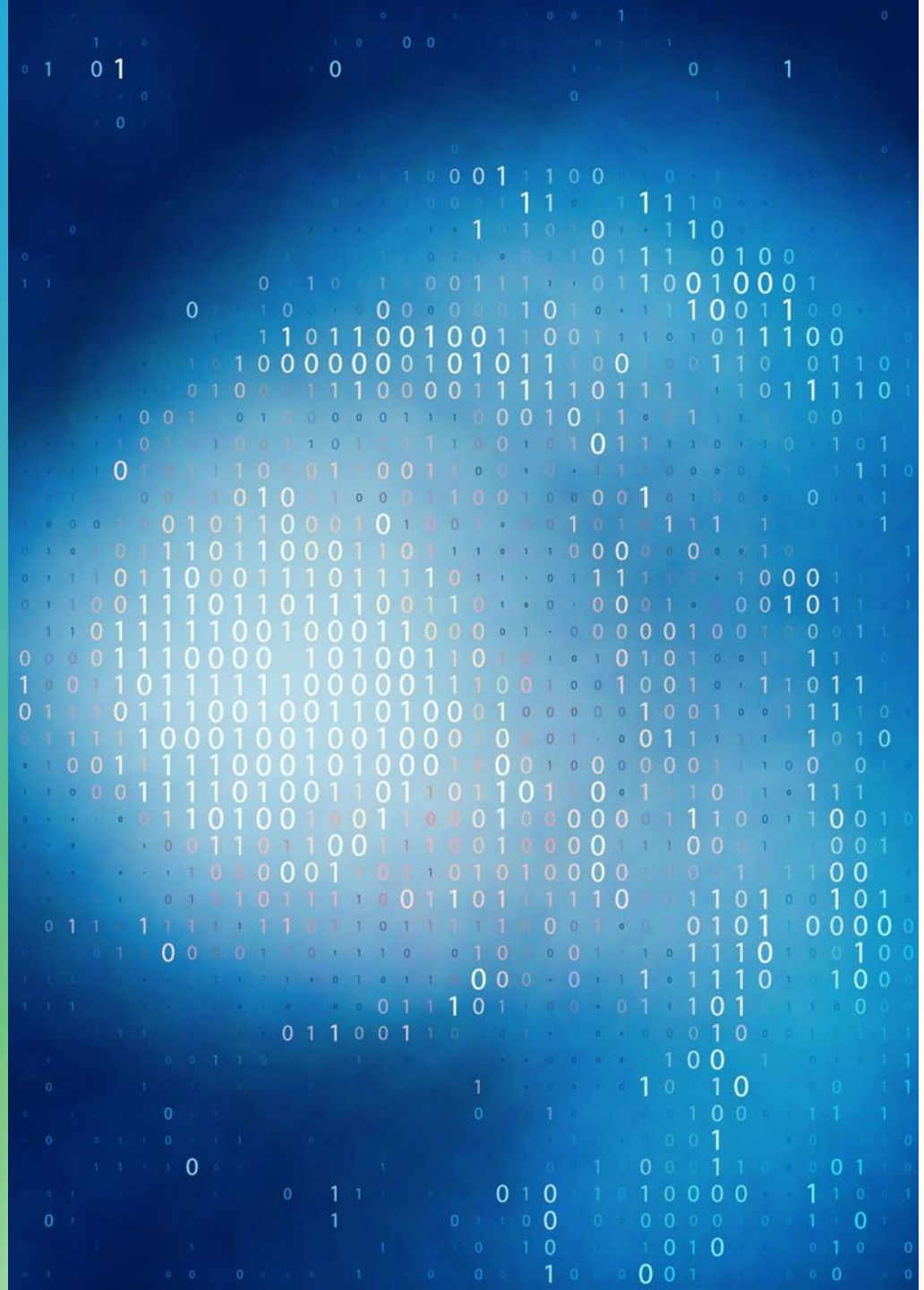
Radio Frequency Jamming

Attackers use radio frequency jamming to disrupt wireless signals and impair network communication.

Wireless Network Protection

Encryption, VPNs, and access controls are essential to securing wireless networks in mobile environments.

Application Security Threats



Injection and Buffer Overflow Attacks

Injection Attacks

Injection attacks exploit input validation flaws in SQL, XML, DLL, and LDAP to gain unauthorized access or control.

Buffer Overflow Threats

Buffer overflow occurs when excess data overwrites memory, causing crashes or privilege escalation exploits.

Secure Coding Practices

Writing secure code, validating inputs, and updating software are essential to prevent injection and overflow attacks.



Phishing and Email Threats

Phishing and Variants

Phishing uses deceptive messages to steal data, with variants like spear phishing, vishing, pharming, and whaling increasing risks.

Spam and Malicious Content

Spam emails often carry malicious links or attachments that can compromise security if clicked or downloaded.

Recognizing and Reporting

Learning to identify suspicious emails, using filters, and reporting threats helps maintain email security.

Promoting Safe Usage

Safe email and browser usage training reduces risks and protects sensitive information effectively.



Other Application Threats

Types of Application Attacks

Common threats include CSRF, race conditions, improper input, error handling, API abuse, replay attacks, directory traversal, and resource exhaustion.

Exploitation of System Flaws

These attacks exploit vulnerabilities in system design and user behavior to compromise applications.

Mitigation Strategies

Secure coding, monitoring application behavior, and using security tools help detect and prevent these threats.



Defending Applications

Secure Coding Practices

Writing secure code and validating inputs reduce vulnerabilities and prevent application attacks effectively.

Software Updates

Regularly updating software patches known vulnerabilities to protect applications from exploits.

User Education and Email Policies

Educating users and implementing email policies help prevent phishing and social engineering attacks.

Antivirus and Anti-Phishing Measures

Using antivirus tools and joining anti-phishing groups strengthen organizational defenses against attacks.

Threat Actors and Impact

Types and Evolution of Threat Actors



Varieties of Threat Actors

Threat actors include amateurs, hacktivists, cybercriminals, state-sponsored groups, and terrorists with varied motivations.

Motivations Behind Attacks

Threat actors' motivations range from financial gain to political and ideological agendas influencing their targets.

Evolution of Attackers

The evolution includes script kiddies, vulnerability brokers, and organized crime adapting tactics over time.

Importance of Understanding Profiles

Studying threat profiles helps anticipate attack methods and develop effective defenses against cyber threats.



Impact of Cyber Threats

Targets of Cyber Threats

Cyber threats commonly target personal, health, and sensitive information for identity theft and fraud.

Consequences of Cyber Attacks

Cyber attacks lead to loss of trust, economic disruption, and damage to competitive and national security interests.

Importance of Cybersecurity

Proactive cybersecurity defense strategies are vital to mitigate risks and safeguard data and systems.

Security Strategy



Levels of Impact

Low

- The loss could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals

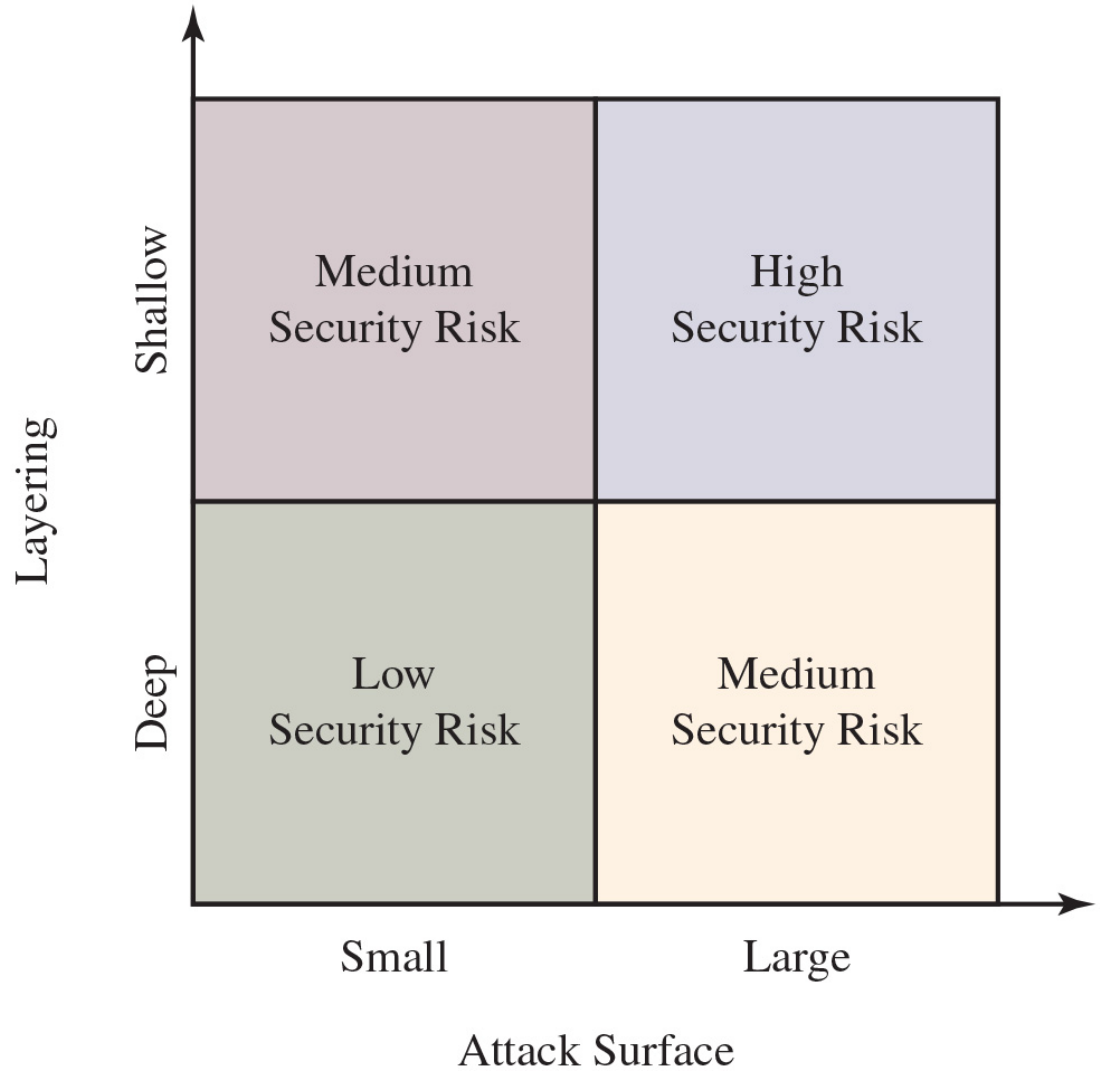
Moderate

- The loss could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals

High

- The loss could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals

Defense in Depth and Attack Surface



Computer Security Strategy

1. Security Policy
    - Formal statement of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources
2. Security Implementation
    - Involves four complementary courses of action:
        - Prevention
        - Detection
        - Response
        - Recovery
3. Assurance
    - Encompassing both system design and system implementation, assurance is an attribute of an information system that provides grounds for having confidence that the system operates such that the system's security policy is enforced
4. Evaluation
    - Process of examining a computer product or system with respect to certain criteria
    - Involves testing and may also involve formal analytic or mathematical techniques

Standards (1 of 2)

- Standards have been developed to cover management practices and the overall architecture of security mechanisms and services
- The most important of these organizations are:
  1. National Institute of Standards and Technology (NIST)
     - NIST is a U.S. federal agency that deals with measurement science, standards, and technology related to U.S. government use and to the promotion of U.S. private sector innovation
  2. Internet Society (ISOC)
     - ISOC is a professional membership society that provides leadership in addressing issues that confront the future of the Internet and is the organization home for the groups responsible for Internet infrastructure standards

Standards (2 of 2)

3. International Telecommunication Union (ITU-T)
   - ITU is a United Nations agency in which governments and the private sector coordinate global telecom networks and services
4. International Organization for Standardization (ISO)
   - ISO is a nongovernmental organization whose work results in international agreements that are published as International Standards

Conclusion and Questions